Apexfiend — Network Penetration Test Report

Prepared by Jean Pierre Miranda Torres | Offensive Security Practitioner | [Assessment Period: TBD] | CONFIDENTIAL

1. Statement of Confidentiality

This document contains confidential and proprietary information regarding the security posture of Apexfiend's network infrastructure. It is intended solely for the use of authorized personnel within Apexfiend and the engagement's designated points of contact. The contents of this report, including all findings, technical details, and recommendations, must not be disclosed, distributed, or reproduced in whole or in part without the prior written consent of the assessment team.

All testing activities described herein were conducted under an authorized engagement, within the scope and timeframe agreed upon with Apexfiend. Unauthorized use of the information contained in this report to access, probe, or otherwise interact with Apexfiend's systems is strictly prohibited and may constitute a criminal offense.

2. Introduction

Apexfiend engaged [Assessment Team / Practitioner Name] to perform a network penetration test of its external and internal infrastructure. The objective of this engagement was to identify, validate, and assess the exploitability of security weaknesses across Apexfiend's perimeter and internal Active Directory environment, simulating the tactics, techniques, and procedures (TTPs) of a real-world adversary with no prior access or credentials.

This report documents the methodology followed, the overall security posture observed, the attack paths that led to full compromise of the Apexfiend Active Directory domain, and detailed findings with corresponding risk ratings and remediation guidance. A separate, detailed technical write-up documenting the step-by-step exploitation process is provided to Apexfiend's technical staff as a companion artifact to this report and is referenced where relevant but not reproduced here.

This document is organized as follows: Section 3 provides an Executive Summary intended for leadership and non-technical stakeholders; Section 4 summarizes the assessment at a glance; Section 5 describes the methodology applied; Section 6 provides

a high-level overview of the attack paths identified; Section 7 presents a prioritized remediation roadmap; Section 8 details each technical finding individually; and Sections 9–10 close the report with conclusions and supporting appendices.

3. Executive Summary

Apexfiend's network was found to be vulnerable to full Active Directory domain compromise, achievable from an unauthenticated, external starting position with no prior knowledge of internal systems or valid credentials. Multiple, independently exploitable weaknesses — spanning web application security, credential hygiene, internal collaboration platform exposure, Active Directory access control, and certificate services configuration — allowed the assessment team to pivot from a public-facing web server to Domain Administrator-equivalent control of the environment.

No single finding in isolation represents the full risk to Apexfiend; rather, the combination of a weak perimeter, predictable credential patterns, overly permissive delegation in Active Directory, and a misconfigured certificate enrollment service formed a continuous, low-friction attack chain. This is a common and realistic pattern observed in modern enterprise compromises, where attackers chain several moderate-severity issues together to achieve critical impact.

3.1 Approach

The assessment was conducted as a goal-oriented penetration test rather than a simple vulnerability scan, simulating a realistic external attacker with no initial access, credentials, or insider knowledge. The assessment team followed an iterative methodology of reconnaissance, exploitation, and post-exploitation enumeration, pivoting from each foothold to identify the next viable path toward the engagement's primary objective: full compromise of the Apexfiend Active Directory domain.

Testing was conducted manually wherever possible, supplemented by automated tooling for enumeration and discovery. All actions were performed within the agreed rules of engagement, and particular care was taken to avoid service disruption to production-equivalent systems.

3.2 Scope

The engagement scope comprised both Apexfiend's external-facing perimeter and its internal Active Directory environment, reflecting a combined external-to-internal assessment model:

In scope:

- External perimeter: public-facing web application(s) hosted in the DMZ segment (VLAN 30)
- Internal Active Directory forest `apexfiend.lab` / child domain `corp.apexfiend.lab`
- Internal network segments: application/critical servers (VLAN 40), PKI and automation infrastructure (VLAN 50), internal workstations (VLAN 60)
- Supporting infrastructure: web servers, source control (Gitea), mail server, database servers, certificate authority, CI/CD (Jenkins) infrastructure, and domain-joined workstations

Out of scope:

- The DMZ-hosted, non-domain-joined web server used solely as a backend consumer and not part of the Active Directory environment
- The isolated testing/attacker network segment used by the assessment team (VLAN 90)
- Denial-of-service testing and social engineering against personnel outside of in-application and in-platform pretexting

3.3 Risk Rating Matrix

Findings in this report are rated using a risk model based on CVSS v3.1 base scores, adjusted by the assessment team's judgment of real-world exploitability and business impact within Apexfiend's environment.

Severity	CVSS v3.1 Score Range	Description
Critical	9.0 – 10.0	Directly exploitable issues leading to full system, domain, or data compromise with little to no prerequisite access.
High	7.0 – 8.9	Significant weaknesses that provide substantial unauthorized access or materially facilitate further compromise.
Medium	4.0 – 6.9	Weaknesses that provide a meaningful advantage to an attacker but require additional conditions or chaining to realize full impact.
Low	0.1 – 3.9	Minor issues with limited standalone impact, typically useful only in combination with other findings.

Severity	CVSS v3.1 Score Range	Description
Informational	N/A	Observations that do not represent an immediate risk but are relevant to the organization's overall security posture.

3.4 Assessment Overview and Recommendations

The assessment team achieved full compromise of the Apexfiend Active Directory domain. The attack began with the exploitation of weaknesses in a public-facing web application, which exposed credentials and ultimately a forwarded authentication agent session, allowing a pivot to an internal-network-connected developer workstation. From there, VPN access into the internal network was obtained using harvested and reused credentials.

Once inside the internal network, the assessment team identified and exploited several independent paths rooted in common organizational weaknesses: predictable, pattern-based credentials for new employees; internal collaboration platforms (chat, ticketing) that disclosed sensitive operational information to any authenticated user; and delegated Active Directory permissions (password reset and credential-linked attribute write access) that were broader than necessary for their intended helpdesk function. These weaknesses enabled the team to escalate from a low-privilege, newly-created account to control of multiple internal user accounts and workstations.

From this position, three largely independent escalation paths were identified and validated, each of which alone would have been sufficient to reach Domain Administrator-equivalent access:

- **Database/application path:** A SQL injection vulnerability in an internally-developed web application's reporting functionality, combined with excessive database service-account permissions, allowed operating-system-level command execution on a backend database server.
- **Certificate services path:** A misconfigured certificate template, combined with a vulnerable certificate enrollment web service, allowed an NTLM relay attack that resulted in the issuance of a certificate usable to authenticate as a privileged domain user.
- **CI/CD and delegation path:** Excessive permissions on an automation service account, combined with weak protections on a legacy privileged credential still in use on critical infrastructure, allowed hijacking of an automation process and abuse of Active Directory delegation rights to obtain administrative access to a critical server.

Each of these paths ultimately converged on administrative control of systems with a direct trust relationship to the domain controller, resulting in full domain compromise.

Key recommendations, detailed further in Section 7, include: enforcing input validation and secure coding practices on internally-developed web applications; eliminating predictable, pattern-based credential provisioning for new accounts; reviewing and minimizing delegated Active Directory permissions, particularly those related to password resets and credential-linked attributes; remediating the vulnerable certificate template and enrollment configuration; enforcing least-privilege on service and automation accounts; and establishing an account lockout policy across the domain.

4. Network Penetration Test Assessment Summary

Item	Detail
Assessment type	Combined external-to-internal network penetration test
Assessment period	[Start Date] – [End Date]
Total hosts in scope	17 (3 domain controllers, 8 servers, 5 workstations, 1 developer laptop; excludes the out-of-scope DMZ host and the isolated testing network)
Domain compromised	Yes — full compromise of `corp.apexfiend.lab` achieved
Independent attack paths validated	3 (database/application, certificate services, CI/CD and delegation)
Findings by severity	Critical: 9 · High: 7 · Medium: 8 · Low: 0 · Informational: 0 (24 total)

Severity counts will be finalized once all individual findings in Section 8 are itemized.

5. Methodologies

The assessment was conducted in alignment with industry-standard penetration testing methodologies, including the Penetration Testing Execution Standard (PTES) and guidance from NIST SP 800-115, and was informed by the MITRE ATT&CK framework for mapping observed and simulated adversary techniques. Testing followed a structured, iterative cycle:

1. **Reconnaissance and enumeration** — Passive and active information gathering against in-scope external and, subsequently, internal assets.
2. **Vulnerability identification** — Manual analysis and targeted testing of discovered services and applications, supplemented by automated scanning for triage purposes only.
3. **Exploitation** — Validation of identified weaknesses through controlled exploitation, limited to what was necessary to confirm impact and establish a foothold.
4. **Post-exploitation and pivoting** — Enumeration of newly accessible systems and data from each foothold to identify the next viable step toward the engagement objective.
5. **Privilege escalation and lateral movement** — Iterative escalation of privileges and lateral movement across the environment, following the principle of least detectable footprint where consistent with engagement goals.
6. **Objective validation** — Confirmation of full domain compromise and documentation of all viable paths, not solely the first successful one, to give Apexfiend complete visibility into its attack surface.

All tooling and techniques used are documented in Appendix [X]. Where multiple viable techniques existed for a given step, the assessment team prioritized realistic, low-noise techniques reflective of real-world adversary behavior over the fastest or most convenient option.

6. Attack Path Overview

This section provides a high-level, narrative overview of how the Apexfiend Active Directory domain was compromised, without reproducing step-by-step exploitation detail — that level of detail is provided separately in the accompanying technical write-up.

The compromise began at Apexfiend's **external perimeter**, where weaknesses in a public-facing web application were chained together to move from an anonymous visitor to a foothold on an internal-network-connected developer system, and ultimately to VPN-based access into the internal network as a legitimate (if low-privileged) user.

From this internal foothold, the assessment team leveraged **predictable credential practices** for newly onboarded staff and **information disclosed through internal collaboration and ticketing platforms** to gain access to a helpdesk-tier account. Permissions delegated to helpdesk roles — intended to support routine password resets and account management — were found to be broader than operationally necessary, and were abused to take over additional internal accounts with access to business application and database infrastructure.

From these intermediate footholds, the assessment team identified and independently validated **three separate escalation paths** into the privileged tier of the Active Directory environment: one rooted in a web application's database layer, one in the organization's internal certificate services, and one in automation/CI infrastructure combined with legacy credential exposure. Each path was pursued to completion and resulted in administrative access to a system trusted by the domain, from which full domain compromise was achieved.

The diversity and redundancy of these paths is itself a significant finding: even full remediation of any single path would not have prevented domain compromise, underscoring the need for defense-in-depth remediation across all findings in Section 8, rather than treatment of any one issue as sufficient.

7. Remediation Summary

The findings in Section 8 are grouped below into a prioritized remediation roadmap. Short-term items address the most direct and highest-impact exposures and should be treated as immediate priorities; medium-term items close structural weaknesses that enabled escalation; long-term items reflect process and architectural improvements that reduce the organization's overall attack surface.

7.1 Short Term (0–3 months)

- Fix the web application reset-token and identity-header validation flaws (F-01, F-02) — these allow unauthenticated full account takeover.
- Patch the XXE, LFI/RCE, and container-escape issues in the public-facing web application (F-03, F-04, F-05).
- Rotate all credentials and tokens exposed via version control and internal documentation (F-06, F-16, F-19), and extend the existing rotation process to cover every in-scope host.
- Remediate the SQL injection and disable unnecessary command-execution capability on the affected database service accounts (F-14, F-15).
- Disable NTLM relay on the Certificate Authority's web enrollment endpoint or enforce Extended Protection for Authentication / channel binding (F-17).
- Correct the service binary-path permissions on the automation service and the unenumerated writable path in the application-control policy (F-20, F-21).
- Set the domain's machine account quota to 0 (F-23).

7.2 Medium Term (3–6 months)

- Review and tighten all delegated Active Directory permissions, in particular password-reset rights and credential-linked-attribute write access granted to helpdesk-tier groups (F-11), and the WriteDacl/WriteProperty rights held by the automation group over infrastructure OUs (F-22).
- Implement a formal account lockout policy domain-wide (F-13).
- Formalize the employee offboarding process to ensure departed-employee accounts are disabled and reviewed immediately (F-12).
- Eliminate predictable, pattern-based initial passwords for new hires; issue unique, random credentials with mandatory first-login change (F-09).
- Restrict sensitive operational information shared on internal collaboration and ticketing platforms to need-to-know channels (F-10).
- Reconfigure privileged scheduled tasks to run under dedicated, non-interactive service accounts rather than human user sessions (F-18).
- Enable the existing restrictive egress firewall rules across DMZ and internal VLANs (F-24).

7.3 Long Term (6+ months)

- Adopt a secrets-management solution (vault or managed identity) across development and automation workflows to eliminate credentials stored in source control or configuration files (F-06, F-16, F-19).
- Deploy a managed local-administrator-password solution (e.g. LAPS) to eliminate shared or patterned local credentials domain-wide.
- Establish a continuous Active Directory ACL and delegation review process (quarterly or automated), rather than one-time remediation of F-11 and F-22.
- Conduct a full certificate services (AD CS) security review across all templates and enrollment interfaces, beyond the single template identified in F-17.
- Introduce secure-development-lifecycle practices (input validation standards, code review, pre-commit secret scanning) for all internally-developed applications to prevent recurrence of the web application findings (F-01–F-05).
- Re-architect network segmentation with default-deny egress as a standing policy, with exceptions explicitly justified and reviewed (builds on F-24).

8. Technical Findings Details

This section details each individual technical finding identified during the assessment, grouped by functional area. Severity ratings follow the matrix defined in Section 3.3. CVSS scores shown are preliminary base-score estimates and should be reviewed/finalized

before external distribution.

8.1 External Perimeter & Web Application

F-01 — Insecure Direct Object Reference (IDOR) Exposing MFA Enrollment Data

- Severity: Critical (CVSS ~9.1)
- Affected asset: Public-facing web application (WEB01)
- Description: The application trusted a client-supplied header to determine the requesting user's identity, rather than validating it server-side. An attacker could manipulate this header (an MD5 hash of a predictable numeric user ID) to retrieve another user's TOTP/MFA enrollment QR code.
- Impact: Complete bypass of multi-factor authentication for any targeted account, including administrative accounts.
- Recommendation: Enforce server-side session-based identity validation for all sensitive endpoints; never trust client-supplied identity headers.

F-02 — Forgeable Password Reset Token

- Severity: Critical (CVSS ~9.4)
- Affected asset: WEB01
- Description: The password-reset workflow issued JSON Web Tokens that were not cryptographically verified server-side, allowing an attacker to forge a valid reset token for an arbitrary account.
- Impact: Full account takeover, including administrative accounts, without any prior credential knowledge.
- Recommendation: Sign and verify all reset tokens server-side using a vetted library; enforce short expiry and single-use semantics.

F-03 — XML External Entity (XXE) Injection via SVG Upload

- Severity: High (CVSS ~8.2)
- Affected asset: WEB01
- Description: The file upload feature parsed user-supplied SVG files without disabling external entity resolution, allowing disclosure of local server files, including application configuration.
- Impact: Disclosure of sensitive configuration data, facilitating further compromise.
- Recommendation: Disable external entity processing in all XML parsers; validate and sanitize uploaded SVG/XML content.

F-04 — Local File Inclusion Leading to Remote Code Execution

- Severity: Critical (CVSS ~9.8)

- Affected asset: WEB01 (containerized application)
- Description: User-controllable profile data (bio field) containing PHP code was written to a session file that was subsequently included by the application, resulting in server-side code execution as the web service account.
- Impact: Remote code execution within the application container.
- Recommendation: Never include user-controllable session or profile data as executable code; apply strict output encoding and a least-privilege execution context for the web service.

F-05 — Container Escape via Argument Injection

- Severity: High (CVSS ~8.8)
- Affected asset: WEB01 (host/container boundary)
- Description: A filename parameter passed to a privileged helper process was not sanitized, allowing argument injection that broke out of the container's intended execution context to the underlying host.
- Impact: Code execution as a host-level user outside the container's intended isolation boundary.
- Recommendation: Strictly validate and sanitize all filenames/arguments passed to subprocesses; avoid invoking shells with attacker-influenced arguments.

F-06 — Secrets Exposed via Version Control History

- Severity: Medium (CVSS ~6.5)
- Affected asset: Internal Gitea instance
- Description: A dangling (unreferenced but still accessible) git commit in a public-facing internal repository contained a valid access token, which provided access to a private repository containing deployment-related secrets and internal network details.
- Impact: Disclosure of credentials and internal infrastructure details, facilitating lateral movement.
- Recommendation: Rotate exposed tokens immediately; implement pre-commit secret scanning and purge sensitive data from git history.

F-07 — Insecure SSH Agent Forwarding

- Severity: High (CVSS ~7.5)
- Affected asset: Developer workstation (DEV-LAPTOP) via WEB01
- Description: A live, forwarded SSH agent socket was left accessible on a compromised host, allowing any process with access to that host to authenticate outward as the forwarding user without needing their private key.
- Impact: Lateral pivot from the compromised web server to an internal developer workstation.

- Recommendation: Prohibit SSH agent forwarding to untrusted or internet-facing hosts; use short-lived certificates or jump-host-confined forwarding instead.

F-08 — Browser-Stored Credentials and Password Reuse

- Severity: High (CVSS ~7.8)
- Affected asset: DEV-LAPTOP
- Description: Credentials stored in the browser's password manager were recovered and decrypted locally. Password reuse between this credential and a local password-manager vault allowed the vault to be unlocked, exposing domain credentials.
- Impact: Disclosure of valid domain credentials, enabling VPN and internal network access.
- Recommendation: Enforce an organizational password manager with unique, non-reused master credentials; disable or restrict browser-based credential storage on corporate endpoints.

8.2 Identity, Credentials & Active Directory Delegation

F-09 — Predictable New-Employee Credential Pattern

- Severity: High (CVSS ~8.1)
- Affected asset: Domain-wide (new-hire provisioning process)
- Description: Newly provisioned accounts were assigned passwords following a guessable, documented pattern, and new hires were not required to change this password before it could be used for the first login window observed.
- Impact: Account takeover of any recently onboarded user without any credential disclosure or exploitation required.
- Recommendation: Issue unique, random initial passwords per account and enforce mandatory change at first logon; avoid any documented or inferable pattern.

F-10 — Sensitive Operational Information Disclosed via Internal Collaboration Platforms

- Severity: Medium (CVSS ~5.9)
- Affected asset: Internal chat/ticketing platform
- Description: Public or broadly-accessible channels on the internal collaboration platform contained operational details (credential patterns, onboarding process, infrastructure references) usable to plan further attacks.
- Impact: Materially facilitated multiple subsequent stages of the compromise.
- Recommendation: Restrict sensitive operational discussions to need-to-know channels; review platform-wide channel access policies.

F-11 — Excessive Active Directory Delegation to Helpdesk Tier

- Severity: Critical (CVSS ~9.0)
- Affected asset: Active Directory — OU=HelpDesk-L2, OU=WebOperations
- Description: The Tier-1 helpdesk group held a Reset Password extended right over the Tier-2 helpdesk OU, and the Tier-2/support group held WriteProperty over the credential-linked-attribute on the WebOperations OU. In combination, these allowed a low-privilege helpdesk account to reset a dormant higher-tier account and subsequently perform a Shadow Credentials attack against an active, unrelated business user.
- Impact: Privilege escalation from a brand-new, low-privilege account to control of business-critical user accounts.
- Recommendation: Apply least-privilege delegation: scope password-reset rights narrowly, and remove or tightly restrict credential-linked-attribute write delegation outside of dedicated PAM/Hello for Business tooling.

F-12 — Dormant Account Not Disabled or Reviewed (Offboarding Gap)

- Severity: Medium (CVSS ~6.1)
- Affected asset: Active Directory — former-employee account
- Description: An account belonging to a departed employee remained enabled with its original group memberships and permissions intact.
- Impact: Provided a viable, lower-scrutiny target for the password-reset/takeover technique described in F-11.
- Recommendation: Implement a formal offboarding process that disables accounts and reviews/removes group memberships immediately upon departure.

F-13 — No Account Lockout Policy

- Severity: Medium (CVSS ~5.3)
- Affected asset: Domain-wide password policy
- Description: The domain password policy did not enforce an account lockout threshold, allowing unlimited authentication attempts against any account.
- Impact: Removes a key control against online password guessing and credential-pattern abuse (compounds F-09).
- Recommendation: Configure a reasonable account lockout threshold and duration, balanced against denial-of-service considerations.

8.3 Database Services

F-14 — SQL Injection via Dynamic SQL in Stored Procedure

- Severity: Critical (CVSS ~9.6)

- Affected asset: Database server (reporting instance), reached via application database and a linked server
- Description: A stored procedure executing with elevated rights constructed a dynamic SQL query from unsanitized user input, and was reachable through a cross-server linked-server call. This allowed injection of arbitrary SQL, including server configuration changes.
- Impact: Full compromise of the query's execution context, used to enable operating-system command execution.
- Recommendation: Eliminate dynamic SQL construction from user input (use parameterized queries); avoid executing stored procedures with elevated context over linked-server connections without additional validation.

F-15 — Excessive Database Service Account Privileges Enabling OS Command Execution

- Severity: Critical (CVSS ~9.1)
- Affected asset: Reporting database server
- Description: The database service account used by the exploited procedure had sufficient privilege to modify server configuration and enable extended command-execution stored procedures, allowing operating-system-level command execution from within the database engine.
- Impact: Operating-system-level code execution on a backend database server.
- Recommendation: Run application-facing SQL logins with the minimum privilege required; explicitly disable and restrict configuration-changing and command-execution capabilities for non-administrative accounts.

F-16 — Credentials Stored in Internal Source Control

- Severity: Medium (CVSS ~6.3)
- Affected asset: Internal Gitea instance (developer workspace repository)
- Description: A repository accessible from a compromised developer account contained application database credentials and internal procedure documentation in plaintext.
- Impact: Facilitated discovery and reuse of valid application credentials.
- Recommendation: Remove credentials from source control; adopt a secrets-management solution (vault/managed identity) for application connection strings.

8.4 PKI / Certificate Services

F-17 — Misconfigured Certificate Template Enabling Relay-Based Privilege Escalation

- Severity: Critical (CVSS ~9.3)

- Affected asset: Certificate Authority and its HTTP web enrollment endpoint
- Description: A certificate template delegated enrollment rights to a non-privileged user, and the CA's HTTP web enrollment service was reachable without NTLM relay/channel-binding protections. This allowed an attacker to lure the privileged enrollee into authenticating to a rogue endpoint, relaying that authentication to the CA, and obtaining a certificate usable to impersonate that user.
- Impact: Issuance of a valid authentication certificate for a privileged domain account without knowledge of its password, enabling full impersonation.
- Recommendation: Disable NTLM on CA web enrollment interfaces or enforce Extended Protection for Authentication (EPA)/channel binding; require HTTPS-only enrollment; review and restrict Enroll permissions on all certificate templates.

F-18 — Interactive Scheduled Task Exposing Cached Privileged Ticket

- Severity: High (CVSS ~7.6)
- Affected asset: Reporting database server, PKI auditor workstation
- Description: A scheduled task belonging to a privileged PKI-auditor account was configured to run interactively rather than under a dedicated service context, leaving a usable cached Kerberos ticket recoverable by anyone with code execution on the host at the time the task ran.
- Impact: Enabled ticket-based impersonation of a privileged user without credential disclosure.
- Recommendation: Configure scheduled tasks under dedicated, non-interactive service accounts; avoid running privileged automation under a human user's own session.

8.5 Automation, CI/CD & Delegation Abuse

F-19 — Legacy Shared Credential Pattern Still Valid on Critical Infrastructure

- Severity: High (CVSS ~8.4)
- Affected asset: CI/CD host
- Description: Historical internal documentation referenced a deprecated local-administrator credential pattern. While rotated on most hosts, this pattern remained valid on a subset of critical infrastructure that had not been included in the credential rotation.
- Impact: Local administrator access to critical CI/CD infrastructure.
- Recommendation: Ensure credential rotation processes cover all in-scope hosts without exception; eliminate shared/patterned local-administrator credentials in favor of a managed local-admin-password solution.

F-20 — Application Control Bypass via Unenumerated Writable Path

- Severity: Medium (CVSS ~6.8)
- Affected asset: CI/CD host
- Description: While the application-control policy correctly restricted execution from the primary automation and user-writable directories, a writable system path was not covered by any rule, allowing a payload to be placed and executed from that location.
- Impact: Bypass of application control, enabling arbitrary code execution despite enforcement mode being active.
- Recommendation: Conduct a full writable-path audit against the application-control policy rather than rule-by-known-location coverage; consider default-deny path rules with narrow allow-listing.

F-21 — Automation Service Account Hijack via Service Binary Path Modification

- Severity: Critical (CVSS ~8.9)
- Affected asset: CI/CD host, automation service
- Description: Local administrative access allowed modification of a Windows service's binary path. Restarting the service executed attacker-controlled code in the context of the service's managed service account.
- Impact: Code execution as a privileged automation service account.
- Recommendation: Restrict local administrative rights on automation hosts; apply service-level ACL hardening to prevent binary-path modification by non-owning accounts; monitor for service configuration changes.

F-22 — Excessive Delegated AD Rights on Infrastructure OU Enabling RBCD

- Severity: Critical (CVSS ~9.0)
- Affected asset: Active Directory — infrastructure OU
- Description: The automation group held WriteDacl and inherited WriteProperty rights directly on an organizational unit containing critical server computer objects, allowing Resource-Based Constrained Delegation to be configured against a critical server without any additional self-granted permissions.
- Impact: Enabled impersonation of arbitrary domain users (including Domain Administrators) against the targeted server.
- Recommendation: Remove WriteDacl/write-level permissions from automation/service groups over OUs containing critical computer objects; apply the principle of least privilege to all delegated AD rights, and audit resource-based delegation attributes across the domain.

F-23 — Unrestricted Machine Account Quota

- Severity: Medium (CVSS ~5.4)
- Affected asset: Active Directory domain-wide setting

- Description: The domain's default machine account quota remained unchanged, allowing any authenticated user to create multiple computer accounts, which was leveraged to create an attacker-controlled computer object used in the RBCD attack chain (F-22).
- Impact: Materially lowers the barrier for RBCD and other computer-account-dependent attacks.
- Recommendation: Set the machine account quota to 0 and provision computer accounts through a controlled, audited process.

8.6 Network Segmentation

F-24 — Unrestricted Outbound Firewall Rules Across Internal VLANs

- Severity: Medium (CVSS ~6.0)
- Affected asset: Perimeter firewall — DMZ, application, and PKI/automation VLANs
- Description: Permissive outbound rules were active on multiple internal network segments, while more restrictive rules existed but were disabled.
- Impact: Facilitates data exfiltration and command-and-control channels from any compromised host on the affected segments.
- Recommendation: Enable and enforce the existing restrictive egress rules; apply default-deny outbound filtering with explicit allow-listing per segment.

9. Conclusion

This assessment demonstrated that an external attacker with no prior access or credentials could achieve full compromise of the Apexfiend Active Directory domain. The path to that outcome did not rely on a single critical flaw, but on the cumulative effect of weaknesses across the environment: a vulnerable public-facing web application, predictable credential practices, over-delegated Active Directory permissions, and a misconfigured certificate enrollment service. The existence of three independent, fully-validated escalation paths to the same outcome is itself a significant structural finding — it indicates that remediating any single issue, however severe, would not have been sufficient to prevent domain compromise.

Apexfiend's security team should treat the recommendations in Section 7 as an integrated program rather than a checklist of isolated fixes, with particular attention to the short-term items that address direct, unauthenticated paths to compromise. The assessment team recommends a follow-up validation test after remediation to confirm that the identified paths have been closed and that no equivalent paths were introduced during the remediation process.

The assessment team thanks Apexfiend for its cooperation throughout this engagement and remains available to clarify any finding or recommendation in this report.

10. Appendices

Appendix A — Tools Used

Category	Tools
Reconnaissance & enumeration	Standard network and web enumeration utilities; manual browser-based testing
Web application testing	Manual testing; intercepting proxy for request/response manipulation
Active Directory enumeration	BloodHound-style AD relationship mapping; standard AD/LDAP enumeration tooling
Credential attacks & relay	NTLM relay tooling (ntlmrelayx); Rubeus (Kerberos ticket operations)
Certificate services	Certipy (AD CS enumeration and abuse)
Lateral movement & execution	Impacket toolset (psexec/wmiexec-style remote execution); PowerShell remoting
Privilege escalation (local)	PrintSpoofer; manual service/binary-path analysis

A complete, host-by-host command log is maintained in the companion technical write-up and is available on request.

Appendix B — Testing Timeline

Phase	Activity	Duration
1	Kickoff, scoping, and rules of engagement agreement	[TBD]
2	External perimeter testing and initial foothold	[TBD]
3	Internal network enumeration and lateral movement	[TBD]
4	Privilege escalation and domain compromise validation	[TBD]

Phase	Activity	Duration
5	Reporting and quality review	[TBD]

Dates to be finalized and inserted once the engagement schedule is confirmed.

Appendix C — Glossary of Terms

Term	Definition
AD CS	Active Directory Certificate Services — Microsoft's PKI role for issuing and managing certificates within a domain.
CVSS	Common Vulnerability Scoring System — an industry-standard framework for rating the severity of security vulnerabilities.
DMZ	Demilitarized Zone — a network segment that exposes external-facing services while isolating them from the internal network.
ESC8	A certificate-services relay-based escalation technique abusing HTTP-based certificate enrollment without relay protections.
gMSA	Group Managed Service Account — a Windows account type with automatically managed, rotated credentials for services.
NTLM Relay	An attack that forwards captured NTLM authentication to another service to authenticate as the victim.
OU	Organizational Unit — a container used to organize objects (users, computers, groups) within Active Directory.
PTES	Penetration Testing Execution Standard — a methodology framework covering the phases of a penetration test.
RBCD	Resource-Based Constrained Delegation — an Active Directory delegation model that can be abused for impersonation when misconfigured.

Term	Definition
TTP	Tactics, Techniques, and Procedures — the behaviors and methods used by a threat actor.